

Exploiting Clickjacking Vulnerability to Trigger DOM-Based XSS

Platform: PortSwigger Web Security Academy

Category: Clickjacking / DOM-Based Cross-Site Scripting (XSS)

Tools: Burp Suite, Web Browser

Objective

Exploit a clickjacking vulnerability to trigger a DOM-based XSS flaw by tricking a victim into interacting with a vulnerable web application.

Vulnerability

Clickjacking allows an attacker to trick users into clicking hidden or disguised interface elements. When combined with a DOM-based XSS vulnerability, a victim's interaction can trigger unsafe client-side JavaScript execution.

If the application processes untrusted input through an unsafe DOM sink, an attacker may be able to execute JavaScript in the context of the vulnerable website.

Methodology

1. Analyzed the target application's client-side functionality to identify the DOM-based XSS vulnerability.
2. Identified how user interaction could trigger the vulnerable JavaScript behavior.
3. Examined whether the application could be embedded within an attacker-controlled page.
4. Constructed a proof-of-concept page designed to trick a user into interacting with the vulnerable element.
5. Verified that the intended interaction triggered the DOM-based XSS behavior and completed the lab.

Impact

Successful exploitation may allow an attacker to execute JavaScript in the victim's browser under the vulnerable application's origin. Depending on the application, this could enable unauthorized actions or access to sensitive page data.

Remediation

- Implement a strict Content Security Policy (CSP).
- Prevent untrusted input from reaching unsafe DOM sinks.
- Use safe DOM APIs and context-appropriate output handling.
- Apply appropriate anti-clickjacking protections, such as CSP `frame-ancestors` or `X-Frame-Options`.

References

- PortSwigger Web Security Academy – Clickjacking
- PortSwigger Web Security Academy – DOM-Based XSS
- OWASP Cross-Site Scripting Prevention Cheat Sheet